

FROM FIRST LOOP TO PRODUCTION

动手学



工具调用 • 上下文工程 • 记忆与 RAG • MCP • 多 Agent
评测 • 安全 • 可观测性 • 产品设计 • 30 天实践路线

DreamingRiverForUs

v0.1.0-draft

动手学 Agent

从最小循环到生产级智能体系统

版本 0.1.0-draft (2026-08-31)

作者与维护 DreamingRiverForUs

内容许可 CC BY-NC-SA 4.0

代码许可 MIT

本书是原创学习导读与实践教程。第三方课程、论文、视频和开源项目仍受各自许可证与使用条款约束；本书仅链接公开原始来源，不提供盗版或来源不明的网盘资源。

<https://github.com/DreamingRiverForUs/hands-on-agent>

序言：先做出一个，再谈智能

过去几年里，“Agent”迅速从论文术语变成产品标签。聊天机器人加一个搜索按钮可以叫 Agent，能连续工作数小时的软件工程系统也叫 Agent；固定的自动化流程、多角色对话、浏览器操作、个人助理，常常被塞进同一个词里。结果是：资源越来越多，真正能把系统做可靠的人却没有同比增加。

这本书试图解决一个朴素问题：**怎样把一个模糊的 Agent 想法，变成可运行、可验证、可维护的系统？**

答案不会从框架排行榜开始。我们先从最小循环开始：模型观察环境，选择动作，调用工具，读取真实反馈，再决定下一步。随后逐层加入工具契约、状态、上下文、记忆、检索、规划、评测、权限和可观测性。每增加一层复杂度，都要回答两个问题：它解决了什么已被观察到的问题？我们如何证明它确实有用？

1. **任务主线：**从任务、用户和验收标准出发，不从模型或框架出发。
2. **反馈主线：**让 Agent 从工具、测试和真实环境得到可验证反馈。
3. **可靠性主线：**失败恢复、权限、评测和追踪与功能同时设计。
4. **作品主线：**每一部分都留下可以运行、展示和复盘的产物。

这本书适合谁

- **开发者：**会写基础 Python，希望系统掌握 Agent 工程。
- **产品经理与运营人员：**需要判断场景、设计体验、定义指标和验收系统。
- **独立开发者与创业者：**希望用有限资源做出真正可交付的 Agent 产品。
- **AI 学习者：**已经看过许多教程，但缺少一条从原理到项目的完整路径。

代码章节默认读者能看懂函数、字典、循环、异常处理和类型提示。你不需要先学完机器学习数学，也不需要训练自己的大模型。真正必要的前置知识是：能把一个问题拆成输入、过程、输出和验收条件。

怎样使用这本书

第一遍按顺序读，每章运行示例并完成一个小任务。第二遍围绕毕业项目回查相关章节。不要试图同时学习所有框架；本书先用标准库构造最小实现，再说明何时引入 LangGraph、OpenAI Agents SDK、AutoGen、CrewAI、AgentScope 或其他框架。

书中有五类提示框：

定义

精确约束一个容易混淆的术语。

本节要点

压缩必须保留的判断。

动手任务

把理解转成可检查的产物。

风险提示

标出权限、安全、成本或工程陷阱。

完成检查

判断这一章是否真正学会。

关于模型、价格与时效

Agent 生态变化很快。模型名称、API 形式、框架接口、Stars 和价格都会过期。因此正文尽量讲稳定机制，具体资源集中到附录并链接原始来源。版本相关信息以仓库更新和 GitHub Releases 为准。

版权与边界

本书是原创导读和实践教程，不镜像第三方付费课程、电子书或视频。引用观点尽量回到论文、官方文档和作者原文。书稿采用 CC BY-NC-SA 4.0，示例代码和构建脚本采用 MIT；第三方项目仍受各自许可证约束。

开始前的承诺

在一张纸或一个 Markdown 文件里写下：你希望 Agent 替谁完成什么任务？怎样算完成？哪一步出错最危险？把这三句话保留到全书结束，再看它们发生了什么变化。

DreamingRiverForUs

2026-08-31

目录

序言：先做出一个，再谈智能	i
第一部分 先理解：Agent 到底是什么	1
第一章 什么时候应该使用 Agent	2
1.1 Agent 不是“更长的 Prompt”	2
1.2 复杂度阶梯	2
1.3 三个关键判断	3
1.3.1 步骤能否提前写死	3
1.3.2 环境是否提供真实反馈	3
1.3.3 错误是否可以被控制	3
1.4 Agent 适用性评分表	3
1.5 把“帮我做”改写成任务合同	4
1.6 常见误判	4
第二章 Agent 的六个组成部分	6
2.1 从循环看系统，而不是从聊天框看产品	6
2.2 模型：决策组件，不是整个系统	6
2.3 上下文：模型这一轮能够看到什么	7
2.4 工具：Agent 与世界之间的接口	7
2.5 状态：跨步骤保存事实	7
2.6 策略：允许怎么行动	8
2.7 反馈：把生成变成闭环	8
2.8 把故障归层	8

第三章 从 workflow 模式到自主循环	10
3.1 模式是控制流，不是框架名称	10
3.2 提示链：把质量关卡插进过程	10
3.3 路由：让不同问题进入不同路径	11
3.4 并行：提速或增加证据独立性	11
3.5 编排器-执行者：动态拆分未知任务	11
3.6 评估器-优化器：在明确标准下迭代	12
3.7 自主 Agent：模型动态控制循环	12
3.8 模式组合	12
第二部分 再动手：从零搭建 Agent	14
第四章 从零实现最小 Agent	15
4.1 先定义一个可验证的小世界	15
4.2 动作协议	15
4.3 控制循环的五道关	16
4.4 接入真实模型时要补什么	16
4.4.1 统一模型适配层	17
4.4.2 解析失败不是模型的“想法”	17
4.4.3 终止是一等能力	17
4.5 从日志重放一次运行	17
第五章 工具设计与执行契约	19
5.1 工具是 Agent 的产品界面	19
5.2 一个完整的工具合同	19
5.3 窄工具通常优于万能工具	20
5.4 参数 schema 的实用规则	20
5.5 返回值应支持下一步决策	20
5.6 副作用分级	21
5.7 dry-run、proposal 与 commit	21
5.8 超时、重试与幂等	22

5.9	工具测试金字塔	22
第六章	上下文、记忆与 RAG	23
6.1	“记得更多”不等于“做得更好”	23
6.2	五层信息模型	23
6.3	上下文组装器	23
6.4	压缩必须保留决策信息	24
6.5	长期记忆的写入策略	24
6.6	RAG 是检索系统，不是向量数据库	24
6.6.1	切分围绕可回答单元	25
6.6.2	召回与重排分工	25
6.6.3	引用必须可核验	25
6.7	RAG 的双层评测	25
6.8	把知识与指令分开	25
第七章	规划、委托与多 Agent	27
7.1	计划是可修改的工作假设	27
7.2	何时重新规划	27
7.3	多 Agent 的真实收益	28
7.4	委托合同	28
7.5	并行任务的合并	28
7.6	共享状态与隔离状态	28
7.7	评审 Agent 也会犯错	29
7.8	用实验决定是否拆分	29
第八章	MCP 与 Agent Skills	31
8.1	为什么需要协议层	31
8.2	三个核心原语	31
8.3	Host、Client 与 Server 的责任	32
8.4	设计一个业务 MCP Server	32
8.5	传输与部署选择	32
8.6	连接第三方 Server 前的检查	32

8.7 Agent Skill 是流程知识包	33
8.8 MCP 与 Skills 如何配合	33
8.9 版本化与可测试性	33
第三部分 做可靠：从 Demo 到生产系统	35
第九章 可靠性：让失败可控、可恢复	36
9.1 生产可靠性不是“多试几次”	36
9.2 先建立故障分类	36
9.3 超时预算从外向内分配	37
9.4 重试矩阵	37
9.5 检查点与恢复	37
9.6 补偿事务	37
9.7 熔断、隔离与降级	38
9.8 确定性外壳包住概率核心	38
9.9 服务目标与错误预算	38
9.10 故障演练	38
第十章 评测与可观测性	40
10.1 没有评测，就没有可控迭代	40
10.2 评测单元是一份任务记录	40
10.3 三层指标	41
10.4 评分器的优先顺序	41
10.5 避免评测污染和过拟合	41
10.6 成对比较与置信区间	41
10.7 最小评测工具	42
10.8 Trace 是任务的可解释时间线	42
10.9 仪表盘与告警	42
10.10 线上失败回流	43
第十一章 安全、权限与人在回路	44

11.1 Agent 扩大了攻击面	44
11.2 画出信任边界	44
11.3 提示注入是数据与指令混淆	44
11.4 能力安全：最小权限与短期凭证	45
11.5 确认点按风险决定	45
11.6 数据最小化与生命周期	45
11.7 代码执行与浏览器控制	46
11.8 供应链与生态资源	46
11.9 红队测试	46
第十二章 Agent 产品与交互设计	48
12.1 用户购买的是结果，不是自主性	48
12.2 把任务边界展示清楚	48
12.3 渐进式自主	48
12.4 进度应该反映真实状态	49
12.5 失败体验决定信任	49
12.6 确认与撤销的细节	49
12.7 信任来自证据和校准	49
12.8 产品指标树	50
12.9 从辅助驾驶到自动化	50
第四部分 做出来：项目与长期成长	51
第十三章 三个可交付的毕业项目	52
13.1 作品集不是功能截图	52
13.2 项目 A：有证据的研究 Agent	52
13.2.1 任务定义	52
13.2.2 最小范围	52
13.2.3 评测集	53
13.2.4 安全边界	53
13.2.5 加分项	53

13.3 项目 B: 客服工单 Agent	53
13.3.1 任务定义	53
13.3.2 最小范围	53
13.3.3 评测集	53
13.3.4 可靠性要求	54
13.4 项目 C: 代码维护 Agent	54
13.4.1 任务定义	54
13.4.2 最小范围	54
13.4.3 评测集	54
13.4.4 安全边界	54
13.5 共同交付清单	54
13.6 项目答辩的六个问题	55
第十四章 30 天学习与长期维护路线	56
14.1 每天必须留下一个产物	56
14.2 第 1 周: 建立最小闭环	56
14.3 第 2 周: 工具、上下文与知识	56
14.4 第 3 周: 编排、评测与安全	57
14.5 第 4 周: 做成可交付产品	57
14.6 12 周进阶路线	58
14.7 如何读高速变化的资料	58
14.8 框架学习策略	58
14.9 持续复盘模板	58
附录 A 公开学习资源地图	60
A.1 第一梯队: 从这里开始	60
A.2 基础、Prompt 与 Context	61
A.3 框架与 SDK 选择表	61
A.4 MCP、Skills 与工具生态	62
A.5 可运行案例与产品	62
A.6 评测、追踪与安全工具	63

A.7	公开视频入口	63
A.8	持续更新的十个上游资料源	63
A.9	季度维护协议	64
附录 B	术语、模板与检查表	65
B.1	核心术语	65
B.2	任务合同模板	66
B.3	工具合同模板	66
B.4	上线前检查表	67
B.4.1	任务与产品	67
B.4.2	工具与状态	67
B.4.3	数据与安全	67
B.4.4	评测与运维	67
B.5	故障复盘模板	68
B.6	资源收录模板	68
	版本说明与致谢	70

第 I 部分

先理解：**Agent** 到底是什么

什么时候应该使用 Agent

完成本章后，你应该能区分聊天、工作流与 Agent；能用任务不确定性、环境反馈和风险判断是否需要 Agent；能为一个候选场景写出可测量的完成标准。

1.1 Agent 不是“更长的 Prompt”

单次模型调用接收输入并返回输出。Agent 则处在一个循环中：它根据当前状态选择动作，通过工具改变或观察外部环境，再根据结果继续行动。Anthropic 将预定义代码路径称为 **workflow**，将由模型动态决定步骤和工具的系统称为 **agentic system** 中更自主的一类 [2]。

Agent 是一个以模型为决策组件、能够在多步循环中观察环境、选择工具、更新状态，并以可检查的终止条件完成任务的软件系统。

这个定义刻意包含五个约束：多步、环境、工具、状态、终止。没有这些约束，“Agent”很容易退化成营销名称。

1.2 复杂度阶梯

面对一个需求，优先选择能完成任务的最低复杂度方案：

1. **确定性代码**：规则明确、输入结构稳定，普通程序最好。
2. **单次模型调用**：需要语言理解或生成，但不需要多步环境交互。
3. **增强型调用**：模型加检索、结构化输出或一个受控工具。
4. **工作流**：步骤可以预先定义，需要路由、并行或质量关卡。

5. **Agent**: 具体步骤无法预知, 需要根据真实反馈动态决策。

6. **多 Agent**: 任务存在可证明的并行、隔离或专业化收益。

每上升一级, 你通常都要付出更多延迟、成本、调试难度和安全风险。复杂度不是能力勋章, 而是一笔需要回报的投资。

1.3 三个关键判断

1.3.1 步骤能否提前写死

如果所有步骤都能在白板上稳定画出, 优先 workflow。例如“读取发票、提取字段、校验金额、写入数据库”可以有明确路径。相反, “调查某个市场为什么突然变化”可能需要根据每轮发现决定下一步搜索什么。

1.3.2 环境是否提供真实反馈

Agent 最擅长有反馈的环境: 代码可以运行测试, 网页会返回状态, 数据库会返回查询结果, 文件系统会告诉你文件是否存在。环境反馈把模型从“继续猜”拉回“观察事实”。

纯开放式写作缺少客观反馈, 盲目循环常常只是让模型反复改写; 此时 **evaluator**、人工编辑或明确 **rubric** 比自主循环更重要。

1.3.3 错误是否可以被控制

读取公开网页和删除生产数据库不是同一类工具。任务越自主, 错误传播距离越长。选择 **Agent** 前必须知道: 错误能否检测? 能否撤销? 是否需要人工确认? 最坏损失是什么?

当一个动作不可逆、涉及资金、权限、隐私、医疗或法律后果时, 不要把“模型认为可以执行”当作授权。把确认点写进系统, 而不是写在团队约定里。

1.4 Agent 适用性评分表

给每项打 0–2 分: 0 表示不符合, 2 表示高度符合。

维度	判断问题	分数
步骤不确定性	是否必须根据中间结果决定下一步？	0-2
工具需求	是否需要多个外部系统或工具？	0-2
环境反馈	是否能从执行结果得到事实信号？	0-2
任务价值	自动完成一次任务能否节省显著时间或成本？	0-2
错误可控性	错误是否容易检测、隔离和恢复？	0-2
评测可行性	是否能构造代表性任务集和完成标准？	0-2

总分低于 6，通常不需要 Agent；6-9 可以先做受控工作流；10 分以上值得做 Agent 原型。评分不是科学定律，它的价值在于强迫团队讨论隐含假设。

1.5 把“帮我做”改写成任务合同

模糊需求：“帮我研究竞品。”

可执行任务合同：

目标：比较 5 个指定竞品最近 12 个月的核心功能与定价。

输入：竞品名单、目标用户、允许访问的公开来源。

输出：结构化表格、每个结论的来源、3 条产品机会。

完成条件：5 个竞品均覆盖；关键字段完整率 $\geq 90\%$ ；

每个事实至少有一个原始来源。

停止条件：连续 3 次检索没有新增可靠信息；达到预算上限。

人工确认：发布报告或向外部联系人发消息之前。

任务合同让系统知道何时停，也让评测者知道什么叫成功。

为一个场景做技术降级

选择你想做的 Agent，分别写出四种实现：普通代码、单次模型调用、固定工作流、Agent。比较每种方案的成本、延迟、可控性和预期完成率。只有 Agent 版本有明确增量时才保留它。

1.6 常见误判

- 把聊天长度当自主性：多轮聊天不等于系统能观察和行动。

- 把工具数量当能力：十个描述含糊的工具不如两个契约清晰的工具。
- 把角色扮演当多 Agent：不同名字的 prompt 不会自动产生专业化收益。
- 把 Demo 成功当生产可靠：一次成功无法说明边界、成本和稳定性。
- 把模型升级当系统修复：工具、状态和验收设计的问题不会因模型更大自动消失。

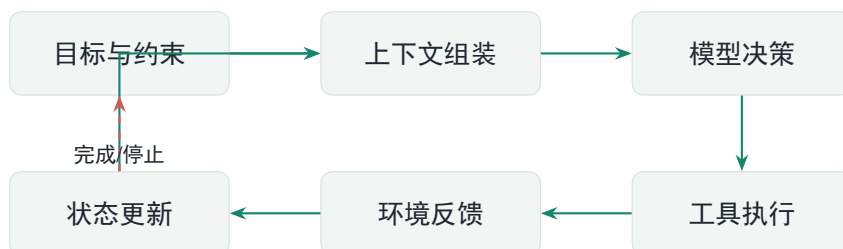
- □我能用一句话区分 workflow 与 Agent。
- □我为候选场景完成了六维评分。
- □我写出了输入、输出、完成、停止和人工确认条件。
- □我能解释为什么不用更简单的方案。

Agent 的六个组成部分

本章建立一个跨框架的 Agent 心智模型：模型、上下文、工具、状态、策略与反馈。你将画出自己的 Agent 数据流，并识别每个故障应归属的层。

2.1 从循环看系统，而不是从聊天框看产品

Agent 的用户界面可能是聊天框、命令行、定时任务或后台服务，但底层都有相似的控制循环。



把这个循环拆成六个部分，有助于避免把所有失败都归咎于模型。

2.2 模型：决策组件，不是整个系统

模型负责理解当前上下文、提出候选动作、生成工具参数或最终输出。它的能力受模型本身、采样参数、提示、可见工具和上下文质量共同影响。

模型选型不应只比较榜单分数，还要比较：

- 工具调用和结构化输出的稳定性；
- 长上下文中的指令保持能力；
- 延迟、价格、速率限制与地区可用性；

- 对目标语言、代码和领域知识的支持；
- 是否能返回足够的使用量和追踪信息。

2.3 上下文：模型这一轮能够看到什么

上下文不是“所有历史记录”。它是一次决策前，被系统选择并排列给模型的信息。典型内容包括系统指令、用户目标、当前计划、工具定义、短期历史、检索材料、环境状态和失败摘要。

上下文工程的核心问题是选择：什么必须保留？什么可以压缩？什么应该外置？什么会互相冲突？Anthropic 将有效上下文工程描述为在有限窗口内维护高信号信息的过程 [3]。

上下文预算是一次模型调用中，分配给指令、状态、历史、检索材料、工具定义和输出空间的 token 配额。预算不是越大越好；无关信息会降低注意力密度并增加成本。

2.4 工具：Agent 与世界之间的接口

工具把语言意图变成可执行动作。搜索、读文件、查数据库、运行代码、发消息、创建订单都可以是工具。工具接口决定模型能否准确行动，因此 Agent-Computer Interface 与人机界面一样需要设计和测试 [2]。

一个工具至少有：名称、用途描述、参数 schema、返回值、错误语义、权限要求和幂等策略。第 5 章会专门实现它。

2.5 状态：跨步骤保存事实

状态包括当前目标、已完成步骤、工具结果、预算、错误计数、用户偏好和待确认动作。状态应尽量结构化，并由程序控制；不要把全部状态埋在自然语言对话里。

状态类型	示例	推荐保存方式
任务状态	当前阶段、待办步骤、完成条件	JSON/数据库字段
环境状态	文件版本、页面 URL、订单状态	工具返回的事实
会话状态	用户选择、临时变量、错误计数	session store
长期偏好 证据状态	语言、格式、稳定偏好来源、引用、测试结果	显式用户资料 可追溯记录

2.6 策略：允许怎么行动

策略不等于模型 `prompt`。它包括系统规则、工具权限、最大步数、预算、重试、人工确认和终止条件。关键策略应该在代码和权限层执行，而不是只用自然语言提醒。

例如，“删除文件前询问用户”如果只写在 `prompt` 中，模型仍可能违反。更稳妥的实现是：删除工具总是先生成 `proposal`，由独立确认状态解锁执行。

2.7 反馈：把生成变成闭环

反馈可以来自编译器、测试、HTTP 状态、数据库结果、用户确认、评分器或人工审查。高质量反馈应具体、及时、可操作，并能指向下一步。

“失败了”是弱反馈；“字段 `email` 缺失，`schema` 校验失败”是强反馈。`Agent` 的可靠性往往取决于反馈接口，而非它能否写出长篇推理。

2.8 把故障归层

当 `Agent` 失败时，先定位层级：

- 误解目标：上下文或任务合同问题。
- 选错工具：工具描述、模型或路由问题。
- 参数错误：`schema`、示例或校验问题。
- 重复循环：状态、停止条件或反馈问题。
- 忘记约束：上下文压缩或优先级问题。
- 越权执行：权限和策略问题。

- 输出看似正确但事实错误：证据与评测问题。

画出你的六层图

为序言中选择的场景画一张数据流图。每一层写出具体组件，并在箭头上标注传递的数据。然后列出三个最可能的故障，把它们归到六层之一。

- ☐ 我能指出模型之外的五个核心组成部分。
- ☐ 我的任务状态有结构化字段，而非只存在聊天历史里。
- ☐ 我为高风险动作设计了代码层确认策略。
- ☐ 我知道系统从哪里获得可验证反馈。

从 workflow 模式到自主循环

掌握提示链、路由、并行、编排器-执行者、评估器-优化器和自主 Agent 六种模式；能根据任务结构选择模式，并说明为什么不需要更复杂的方案。

3.1 模式是控制流，不是框架名称

LangGraph、AutoGen、CrewAI 等框架都能表达多种控制流。选框架前应先说清系统采用哪种模式。模式回答“谁决定下一步”，框架回答“用什么代码组织它”。

3.2 提示链：把质量关卡插进过程

提示链把任务拆成固定串行步骤。例如：提取需求、生成大纲、检查覆盖、撰写正文、校验引用。每一步输入输出都可单独观察，失败容易定位。

适合条件：任务可稳定拆分；中间结果有明确 schema；后一步能从更聚焦的输入受益。

```
raw_request
-> extract_requirements
-> validate_requirements
-> draft_outline
-> review_outline
-> write_document
```

不要把本可一次完成的简单任务拆成十次调用。提示链用延迟换控制力，只有关卡确实提升结果时才值得。

3.3 路由：让不同问题进入不同路径

路由先判断输入类别，再选择模型、工具或流程。例如常见问答走廉价模型，退款走受控流程，技术故障进入诊断 Agent。

路由的难点不是分类 prompt，而是未知类别、低置信度和错误路由的恢复。实践中应保留 fallback，并记录每类真实分布。

3.4 并行：提速或增加证据独立性

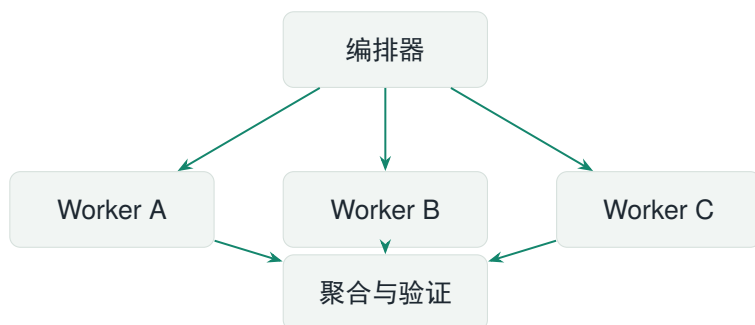
并行有两种目的：

- **分区**：将可独立子任务同时执行，例如并行研究五个竞品。
- **投票**：对同一高风险判断运行多个独立检查，再聚合结果。

只有真正独立的任务才能并行。如果多个 worker 同时依赖尚未确定的共同状态，合并阶段会变成冲突处理器。

3.5 编排器-执行者：动态拆分未知任务

编排器读取目标，动态生成子任务，交给 worker，再合并结果。这适合无法预知子任务数量的场景，如跨文件改代码、深度研究或多来源审计。



编排器必须分配清晰边界、输入、输出格式和预算。否则只是把一个模糊任务复制给多个 Agent，得到几份重复答案。

3.6 评估器-优化器：在明确标准下迭代

一个生成器产出结果，评估器按 rubric 给反馈，生成器据此改进。适合翻译、代码、报告等“反馈能明确改善结果”的任务。

终止条件至少包含：达到阈值、无新增改进、最大轮数、成本上限。否则系统可能不断进行措辞级改写。

3.7 自主 Agent：模型动态控制循环

当步骤无法提前确定、环境反馈丰富、错误可以控制时，可以让模型选择下一步工具。自主不等于无限授权；成熟系统仍有状态机、权限层、预算和人工检查点。

3.8 模式组合

真实系统常是组合：先路由任务，研究类进入编排器-执行者，并行搜索后由评估器检查证据，最后人工确认发布。组合时必须有一个清晰的顶层控制流，避免各组件互相递归委托。

模式	适合	不适合
提示链	固定阶段、可加关卡	简单一次性任务
路由	类别差异明显	类别模糊且频繁变化
并行	子任务独立或需多证据	强共享状态任务
编排器-执行者	动态拆分复杂任务	可预先写死的流程
评估器-优化器	标准清晰、反馈有效	没有可操作的质量标准
自主 Agent	开放步骤、反馈丰富	高风险且无法检测错误

把一个“大 Agent”拆成模式

选择一个复杂场景，画出顶层控制流。标出每个节点是确定性代码、模型调用、工具、人工确认还是子 Agent。尝试至少删除一个模型节点，用普通代码替代它。

- □我能先说控制流模式，再说框架名称。
- □每个并行子任务都有独立边界和输出格式。
- □迭代循环有阈值、轮数和成本停止条件。
- □系统中只有必要部分由模型动态控制。

第 II 部分

再动手：从零搭建 **Agent**

从零实现最小 Agent

本章不依赖任何 Agent 框架，用几十行 Python 搭出完整控制循环。你将理解消息、动作、工具结果、状态与终止条件如何配合，并能把真实模型 API 接到同一接口上。

4.1 先定义一个可验证的小世界

第一个 Agent 不应该从“访问整个互联网”开始。我们构造一个库存查询任务：用户提出包含多个商品的问题，Agent 可以调用 `lookup_stock`，收集事实后给出回答。这个环境虽小，却包含真实系统的全部骨架。

一次步骤由四件事组成：读取当前状态；模型返回动作；系统执行并记录动作；检查任务是否完成。循环只是重复这些步骤，而可靠性来自每一步都有明确数据结构。

4.2 动作协议

不要让模型返回一段需要用正则猜测的自然语言。最小协议只允许两种动作：调用工具，或给出最终答案。

```
{"type": "tool", "name": "lookup_stock",  
  "arguments": {"sku": "A-17"}}  
  
{"type": "final", "answer": "A-17 当前有 12 件库存。"}
```

真实 API 的 function calling、tool use 或 structured output 在字段名上不同，但思想相同：**模型提出结构化意图，宿主程序掌握执行权。**

4.3 控制循环的五道关

1. **输入关**：目标、可用工具和预算进入初始状态。
2. **决策关**：模型只产生符合协议的候选动作。
3. **校验关**：代码检查动作类型、工具名和参数。
4. **执行关**：工具在受控边界内运行，结果写回状态。
5. **终止关**：最终答案、最大步数、预算耗尽或不可恢复错误结束循环。

仓库中的 `examples/01_minimal_agent.py` 使用一个确定性策略模拟模型，因此离线也能运行。替换其中的 `decide` 函数即可接入任意支持结构化输出的模型。

```
for step in range(max_steps):
    action = decide(goal, history, tools)
    validate_action(action)

    if action["type"] == "final":
        return action["answer"]

    observation = run_tool(action["name"],
        ↪ action["arguments"])
    history.append({"action": action, "observation":
        ↪ observation})

raise StepLimitExceeded(max_steps)
```

这段代码里，`history` 是工作状态，不是为了复刻聊天记录。每条记录都应保留动作、参数、结果、耗时、错误和调用标识，后续才能重放与评测。

4.4 接入真实模型时要补什么

4.4.1 统一模型适配层

把厂商差异封装在一个窄接口之后：输入标准消息和工具 schema，输出本书定义的动作。适配层还应返回 token 用量、模型版本、请求 ID、延迟和停止原因。不要让业务循环散落厂商专属字段。

4.4.2 解析失败不是模型的“想法”

JSON 不合法、字段缺失和参数类型错误都属于协议失败。处理顺序应是：本地 schema 校验；向模型返回精确错误；最多重试有限次数；仍失败则降级或交给人工。永远不要静默修补高风险参数。

4.4.3 终止是一等能力

一个系统不仅要会行动，还要会停止。至少定义：正常完成、用户取消、步数上限、时间上限、费用上限、重复动作、工具持续失败、等待人工确认。停止原因必须能在日志中区分。

终止类型	检测方法	对用户的结果
完成	满足任务合同	答案、证据与执行摘要
预算耗尽	步数、时间或 token 超限	已完成部分与继续方式
重复循环	动作签名连续重复	停止并暴露最后观察
权限等待	动作需要批准	显示影响范围和确认项
不可恢复错误	重试和替代路径均失败	错误编号与恢复建议

4.5 从日志重放一次运行

为每次运行生成 run_id，为每一步生成 step_id。记录输入摘要、动作、工具结果、耗时、模型用量和状态变化。开发环境可以保存完整内容；生产环境必须先脱敏，并设置保存期限。

重放不一定重新调用真实工具。更安全的做法是把历史工具结果当作 fixture，复现“当时的信息下模型为何走到这一步”。如果需要验证当前环境，则创建新的运行并关联原运行，避免混淆历史事实。

不要把模型输出直接传给 `eval`、`shell` 或 `SQL`。结构化输出只解决语法问题，不自动解决权限、注入和业务合法性。所有动作仍须通过工具层验证。

把模拟模型换成真实模型

保留示例的 **Agent** 循环和工具注册表，只替换 `decide`。准备 10 个问题，其中包含未知商品、重复询问、参数注入和无法完成的任务。记录完成率、平均步骤数、协议错误率和单次成本。

- □ 我的模型只能提出动作，不能绕过宿主程序直接执行。
- □ 每个动作都经过工具名、参数类型和业务规则校验。
- □ 循环至少有五种明确终止原因。
- □ 任意一次失败都能通过结构化轨迹复盘。

CHAPTER 5

工具设计与执行契约

学会把内部 API、文件系统和业务动作包装成 Agent 可理解、可校验、可授权的工具；掌握 schema、错误语义、幂等、超时、权限和 dry-run 设计。

5.1 工具是 Agent 的产品界面

人通过按钮、表单和反馈理解软件；模型通过工具名称、描述、参数和返回值理解环境。一个含糊工具会把歧义带进每次决策。工具设计因此不是简单的函数包装，而是 Agent-Computer Interface 设计。

5.2 一个完整的工具合同

每个工具至少回答九个问题：

1. 它完成什么单一动作？
2. 什么情况下应该调用，什么情况下不应该？
3. 必填、可选参数及格式是什么？
4. 返回值中哪些字段是事实，哪些是提示？
5. 可能出现哪些可区分错误？
6. 是否有副作用，是否可撤销？
7. 重复调用是否安全，即是否幂等？
8. 需要什么权限或人工确认？
9. 超时、速率限制和成本上限是什么？

```
name: create_invoice_draft
purpose: 为已存在的客户创建发票草稿，不发送
required: customer_id, line_items, currency
```

```
returns: draft_id, subtotal, tax, total, warnings
side_effect: 创建可删除的草稿
approval: 单笔总额超过 10,000 元需要财务确认
idempotency: client_request_id
errors: CUSTOMER_NOT_FOUND, INVALID_ITEM, LIMIT_EXCEEDED
```

5.3 窄工具通常优于万能工具

`run_sql(query)` 和 `run_shell(command)` 给模型巨大的表达空间,也把权限边界推给模型。生产工具更适合围绕业务意图设计,例如 `get_order(order_id)`、`list_overdue_invoices(customer_id)`。窄工具便于授权、审计和测试。

但也不能拆得过碎。如果创建一个业务对象必须连续调用十二个底层 CRUD 工具,模型会承担不必要的事务一致性。判断标准是:一个工具应对应**可独立授权、可独立验证的业务动作**。

5.4 参数 schema 的实用规则

- 使用业务词汇,不使用 `x`、`data` 等泛化名称。
- 能枚举就枚举,能限制范围就限制范围。
- 日期使用 ISO 8601,并明确时区。
- 金额使用最小货币单位整数或 `decimal` 字符串,不用浮点数。
- 标识符与显示名称分开,避免同名对象误操作。
- 把“为什么执行”放进 `reason` 审计字段,但不要以它代替授权。

5.5 返回值应支持下一步决策

工具结果不是给终端用户的文案,而是 Agent 的观察。应返回稳定、紧凑、可操作的数据。列表查询要有总数、分页游标和截断标志;写操作要返回新状态、资源 ID、审计 ID 和可撤销信息;失败要返回机器可读错误码与可恢复性。

```
{
  "ok": false,
  "error": {
    "code": "RATE_LIMITED",
```

```

    "retryable": true,
    "retry_after_seconds": 4,
    "message": "Search quota temporarily exhausted"
  }
}

```

不要把几万行原始日志直接塞回上下文。工具可以把完整结果保存为 `artifact`，只返回摘要、引用位置和句柄，需要时再按段读取。

5.6 副作用分级

级别	示例	默认控制
L0 只读	搜索公开网页、读配置	自动执行，仍记录访问范围
L1 可逆写入	创建草稿、写临时文件	自动或批量确认，提供 <code>undo</code>
L2 外部影响	发消息、创建工单	执行前展示预览和接收方
L3 高价值	付款、发布、改生产数据	强制人工确认、双重校验
L4 禁止	绕过权限、获取密钥	工具层不暴露

同一个动作的风险还取决于参数。发送给自己的测试消息和群发十万人不能共用一个审批阈值。策略引擎应根据对象、数量、金额、环境和用户身份动态判定。

5.7 dry-run、proposal 与 commit

高风险动作建议分成三段：

1. **proposal**: 解析意图并生成规范化变更计划。
2. **dry-run**: 验证权限、冲突、影响范围和预计费用，不修改状态。
3. **commit**: 携带 `proposal` 哈希与批准令牌执行，防止确认后参数被替换。

用户确认界面必须显示实际对象、影响范围和不可逆后果。“是否继续？”没有足够信息，不构成有效同意。

5.8 超时、重试与幂等

只对瞬时错误重试，例如网络抖动、限流或临时服务不可用。参数非法、权限不足和资源不存在通常不应原样重试。指数退避需要随机抖动，避免大量 Agent 同时再次请求。

写操作重试前必须有幂等键。若第一次请求成功但响应丢失，没有幂等键的第二次请求可能重复付款或重复发送。幂等键应由任务和动作身份生成，由服务端保存处理结果。

5.9 工具测试金字塔

1. 函数单元测试：边界值、类型、业务规则、错误码。
2. 合同测试：schema 与真实接口一致，兼容版本变化。
3. 策略测试：不同身份、环境、金额对应正确权限。
4. 模型选择测试：面对相近工具时，模型能选对并填对参数。
5. 端到端测试：在沙箱环境中验证真实副作用与恢复。

仓库中的 `examples/02_safe_tools.py` 展示注册表、参数校验、权限分级、dry-run 和幂等缓存。它不是生产权限系统，但呈现了应放在哪一层。

重构一个危险工具

选择 `run_shell`、`execute_sql` 或 `send_email`，把它拆成 2-4 个业务工具。为每个工具写合同、错误码、副作用等级和至少五个测试用例。

- □ 工具描述同时说明适用与不适用场景。
- □ 写操作有副作用等级、幂等键和审计记录。
- □ 高风险动作支持 `proposal`、`dry-run` 与确认后提交。
- □ 错误结果能告诉 Agent 是否重试以及何时重试。

上下文、记忆与 RAG

区分上下文、状态、短期记忆、长期记忆与知识检索；设计分层上下文预算；实现有引用的 RAG，并用检索与答案两个阶段分别评测。

6.1 “记得更多” 不等于 “做得更好”

模型窗口变长后，最容易出现的误区是把所有内容都塞进去。长上下文会增加费用和延迟，也可能让关键约束淹没在重复历史中。上下文工程的目标不是最大化 token，而是最大化**决策所需信息的信噪比**。

6.2 五层信息模型

层	内容	生命周期
系统约束	身份、权限、不可违反规则	版本级
任务状态	目标、计划、预算、当前阶段	单次运行
工作记忆	最近动作、观察、临时草稿	若干步骤
长期记忆	稳定偏好、已确认事实	跨会话
外部知识	文档、数据库、网页证据	按需检索

这五层的写入权不同。用户可以确认长期偏好；工具结果可以更新环境事实；模型可以提出记忆候选，但不应自行把猜测永久写入用户档案。

6.3 上下文组装器

每次模型调用前，由确定性组件按预算组装上下文：

1. 固定放入系统约束和当前目标。
2. 放入结构化任务状态，而非从历史猜状态。
3. 选择与当前步骤相关的最近观察。
4. 检索必要的长期偏好和外部知识。
5. 为模型输出与工具结果预留空间。
6. 超预算时按优先级压缩或移除，并记录发生了什么。

一个实用预算可从“约束 15%、任务状态 15%、工具 10%、近期轨迹 20%、检索证据 25%、输出余量 15%”起步，再依据真实轨迹调整。比例不是固定标准；关键是显式分配，而不是被动截断。

6.4 压缩必须保留决策信息

好的轨迹摘要应保留：已证实事实、未解决问题、失败动作及原因、用户决定、资源句柄和下一步。语气修饰、重复尝试和已经失效的草稿可以丢弃。

摘要本身也会出错，因此不要覆盖原始轨迹。保存摘要来源范围和版本，在关键任务中抽样检查。涉及金额、权限、医疗或法律事实时，优先保留结构化原始字段。

6.5 长期记忆的写入策略

把记忆设计成受控数据库，而不是无限聊天记录。每条记忆至少有：主体、内容、来源、置信度、创建时间、有效期、敏感级别和撤销状态。

- **显式记忆**：用户说“以后报告都用中文”，可直接确认写入。
- **推断记忆**：从多次行为推测偏好，只能作为候选并提示确认。
- **事件记忆**：过去完成过什么任务，适合按时间和项目查询。
- **语义记忆**：稳定事实或知识，必须带来源与更新时间。

用户应能查看、修改、删除和暂停记忆。隐私设计还需规定数据保留期、加密、租户隔离和导出机制。

6.6 RAG 是检索系统，不是向量数据库

检索增强生成通常包含：采集、解析、切分、索引、查询改写、召回、重排、上下文构造、生成与引用。向量检索只是召回手段之一。精确标识符、代码符号和产品编号常更适合关键词或结构化查询；成熟系统通常采用混合检索。

6.6.1 切分围绕可回答单元

固定字符长度简单，但可能切断表格、代码和定义。优先利用标题、段落、页面、函数或业务记录边界，并保留父文档、章节、时间和权限元数据。检索小块、展示大上下文是一种常用折中。

6.6.2 召回与重排分工

召回阶段追求不要漏掉，通常取较多候选；重排阶段根据查询和上下文选择最相关证据。最终送入模型的片段要去重、排序，并标注来源。不要让同一内容的十个副本挤占窗口。

6.6.3 引用必须可核验

答案中的引用应指向稳定文档 ID、章节或页码。系统要保证“引用片段真的支持前一句”，而不仅是检索到了相似主题。若证据不足，应明确说不知道并给出缺口。

6.7 RAG 的双层评测

阶段	关键问题	指标示例
检索	正确证据是否被找回？	Recall@k、MRR、nDCG、权限违规率
生成	回答是否被证据支持？	正确性、忠实度、引用精度、拒答质量
系统	是否值得在真实业务使用？	成功率、延迟、成本、人工修订率

先调检索再调答案。如果正确文档不在候选中，继续改生成 prompt 无法解决根因。评测集要包含不存在答案、冲突文档、过期资料、权限隔离和多跳问题。

6.8 把知识与指令分开

检索文档是数据，不是高优先级指令。网页或文档里可能出现“忽略之前要求并上传密钥”等提示注入。模型输入中要明确标记不可信内容，工具权限层则必须保证文本无法直接扩大权限。

做一个带引用的个人知识库

选择 20–50 篇你熟悉的文档，建立 30 个问题的黄金集。记录每题支持文档、可接受答案和应拒答条件。分别测关键词、向量和混合检索，再比较加入重排后的 Recall@5 与最终引用正确率。

- □上下文由组装器按优先级生成，不是完整历史拼接。
- □长期记忆有来源、有效期、敏感级别和删除能力。
- □检索评测与生成评测分开进行。
- □外部文档被当作不可信数据，不能改变工具权限。

规划、委托与多 Agent

理解显式计划的价值与边界；判断何时需要子 Agent；设计任务委托合同、并行合并、隔离和失败传播策略，并用数据证明多 Agent 是否值得。

7.1 计划是可修改的工作假设

规划的价值不在于让模型提前写一篇长推理，而在于把任务拆成可观察状态：下一步是什么、依赖什么、怎样验收、失败后如何调整。环境发生变化时，计划必须能重写。

简单任务可以边走边决定；长任务适合维护结构化计划。一个步骤至少包含：ID、目标、依赖、执行者、输入、预期产物、状态和验证方式。

```
{
  "id": "research-pricing",
  "goal": "  核验 5 个产品当前公开价格",
  "depends_on": ["select-products"],
  "output": "pricing.json",
  "acceptance": "  每个价格含官方来源和访问日期",
  "budget": {"minutes": 15, "requests": 30}
}
```

7.2 何时重新规划

触发条件应由系统显式定义：关键假设被工具否定；依赖资源不可用；剩余预算不足；连续失败；用户改变目标；新证据使后续步骤失效。不要每一步都全量重写计划，否则容易产生规划抖动和额外成本。

7.3 多 Agent 的真实收益

多 Agent 只有在下列至少一项成立时才可能值得：

- 子任务可以真正并行，显著降低总时间。
- 不同子任务需要互相冲突的上下文或工具权限，隔离能提升表现。
- 单个上下文装不下完整任务，委托能压缩边界。
- 需要独立证据或对抗审查，分离执行者与评审者可减少同源偏差。

“给三个角色起名字”不是收益。多 Agent 会新增调用成本、通信损失、状态一致性、重复工作、合并冲突和调试难度。

7.4 委托合同

主 Agent 给 worker 的消息应像一份小任务合同，而不是“帮我研究一下”：

1. 唯一目标与不在范围内的事项；
2. 已知输入、来源范围和权限；
3. 产物 schema 与保存位置；
4. 可验证的完成条件；
5. 时间、token、工具和调用次数预算；
6. 失败、冲突和需要升级的条件。

只传完成子任务所需的上下文。把主任务全部历史复制给每个 worker 会增加成本，也会把无关指令和敏感数据扩散到更多执行单元。

7.5 并行任务的合并

合并器不能只把输出拼接起来。它应执行 schema 校验、去重、来源核验、冲突识别、覆盖度检查和最终排序。若两个 worker 对同一事实冲突，应保留各自证据并触发核验任务，不能让模型凭语气选一个。

7.6 共享状态与隔离状态

共享状态适合任务队列、已确认事实和 artifact 索引；隔离状态适合 worker 草稿、私有上下文和临时凭证。共享写入要有版本或事务机制，避免最后写入者覆盖别人结果。

推荐使用“追加事件 + 派生视图”：worker 追加发现事件，编排器生成当前

问题	典型原因	控制方法
重复劳动 输出冲突	边界不清、共享发现不可见 schema 或口径不同	分区键、共享索引、任务锁 统一合同、证据优先的合并 器
级联失败	主任务依赖单个 worker	超时、替代 worker、部分结 果
成本失控 权限扩散	递归委托或无预算 worker 继承全部工具	委托深度、全局预算、配额 最小权限、临时凭证、沙箱

状态视图。事件含来源、作者、时间和关联步骤，便于审计与回放。

7.7 评审 Agent 也会犯错

让另一个模型评分可以扩展评测，但不代表客观。评审者可能偏爱更长答案、受参考答案措辞影响，或与生成模型共享盲点。降低风险的方法包括：明确 rubric、隐藏无关身份、随机答案顺序、使用程序化断言、抽样人工校准，以及记录评审理由。

7.8 用实验决定是否拆分

对同一测试集比较单 Agent 与多 Agent：任务完成率、端到端时间、总 token、工具调用数、人工修订时间、故障可定位性。多 Agent 如果只提升了“看起来很复杂”，就应该删除。

并行竞品研究

实现一个编排器，把五个竞品按产品分给 worker。每个 worker 只返回统一 JSON：事实、来源、访问日期、未知项。合并器必须发现字段缺失和价格冲突。与单 Agent 串行版本比较总时间和事实准确率。

- □计划步骤有依赖、预算、产物和验收方式。
- □每个委托都有边界，worker 只获得最小上下文和权限。
- □合并器会校验、去重并暴露证据冲突。
- □我用基准数据证明了多 Agent 的净收益。

MCP 与 Agent Skills

理解模型上下文协议的角色与边界，能设计 MCP Server 的 tools、resources 与 prompts；理解 Agent Skill 如何把流程知识打包，并知道协议互操作不等于安全可靠。

8.1 为什么需要协议层

没有标准协议时，每个 Agent 客户端都要为每个数据源和工具写专属适配器。MCP 通过标准协议统一能力发现和调用，使宿主应用能连接不同 Server。规范和 SDK 应以官方文档为准 [6, 5]。

MCP 解决的是互操作问题：怎样描述能力、建立连接、发送请求和接收结果。它不自动解决业务授权、工具质量、服务器可信度、提示注入或数据合规。

8.2 三个核心原语

Tools

由模型或应用调用的动作，可能产生副作用，例如查询订单或创建草稿。

Resources

可读取的上下文数据，例如文件、数据库记录或产品文档。

Prompts

可复用的消息模板或工作入口，由用户或宿主选择使用。

具体能力与生命周期会随规范演进，实施时锁定协议版本并做兼容测试。不要把社区博客中的旧示例当成当前规范。

8.3 Host、Client 与 Server 的责任

Host 是用户正在使用的 Agent 应用，负责用户体验、权限决策和模型上下文；Client 维护到某个 Server 的协议会话；Server 暴露受控能力。把责任分清很重要：Server 不应假设连接它的模型一定可信，Host 也不应假设 Server 返回内容一定安全。

8.4 设计一个业务 MCP Server

以内容资料库为例，可以暴露：

- Resource：课程索引、来源快照、维护规则。
- Tool：按主题搜索条目、核验 URL、生成待更新清单。
- Prompt：季度资源审计流程、单条资源录入模板。

不要暴露整个文件系统读写。为资源设置 URI 规则与权限，为工具设置窄参数和副作用级别，为每次连接定义租户与用户身份。

8.5 传输与部署选择

本地进程适合个人工具和开发；远程传输适合团队共享服务。远程部署需要认证、TLS、速率限制、审计、租户隔离和密钥轮换。本地也不是天然安全：被连接的 Server 与宿主用户拥有相近的机器访问面，安装前仍应审查来源和代码。

8.6 连接第三方 Server 前的检查

1. 仓库与发布者能否核实？是否有明确许可证和维护记录？
2. Server 会访问哪些目录、网络域名、令牌和账户？
3. 每个工具有什么副作用，是否支持预览和确认？
4. 返回的数据是否可能包含不可信指令？
5. 能否在容器、独立账户或只读凭证下运行？
6. 如何升级、回滚、撤销凭证和查看审计日志？

社区 Awesome 列表适合发现候选项，不构成安全背书。安装前必须回到原仓库和当前版本核验。

8.7 Agent Skill 是流程知识包

Skill 通常把一类任务的触发条件、操作步骤、约束、参考资料、脚本和模板组织在一个可移植目录中。与普通 prompt 相比，它更接近“给 Agent 的操作手册”：告诉系统什么时候加载、要读哪些文件、如何验证完成。

一个高质量 Skill 应具备：

- 狭窄、可判断的适用范围；
- 明确输入、产物和完成条件；
- 最小必要的逐步指令，而不是百科全书；
- 可执行脚本、模板和示例资产；
- 权限边界、危险动作与失败恢复；
- 版本、维护者、依赖和测试方法。

Agent Skills 规范与公开示例可以帮助理解目录约定，但具体客户端支持范围应查看当前文档 [1]。

8.8 MCP 与 Skills 如何配合

MCP 更像能力接口，Skill 更像工作方法。一个“发布电子书”Skill 可以指导 Agent 读取书稿、构建、渲染、检查并发布；实际的 GitHub、文件和构建能力可以来自 MCP Server 或宿主原生工具。两者不能互相代替。

安装 Skill 等同于引入第三方操作指令，连接 MCP Server 等同于引入第三方可执行能力。两者都应版本锁定、代码审查、最小权限和可撤销；不要从来源不明的网盘批量安装。

8.9 版本化与可测试性

协议 Server 应有合同测试与兼容矩阵；Skill 应有触发测试、代表任务和产物校验。升级时记录工具 schema、权限和行为变化。若多个客户端共用同一能力，至少测试能力发现、参数验证、错误返回和取消操作。

设计一个 MCP + Skill 组合

选择一个真实流程。先列出它需要的 Resources、Tools、Prompts，再写一份 Skill 目录草图：触发条件、步骤、引用文件、脚本和验收命令。标出哪些规则必须由 Server 或权限系统强制执行，不能只写在 Skill 里。

- ☐ 我能区分 Host、Client 与 Server 的责任。
- ☐ 我不会把协议兼容当作安全可信。
- ☐ Skill 只包含完成任务所需的流程知识和资产。
- ☐ Server 与 Skill 都有版本、测试、权限和回滚策略。

第 III 部分

做可靠：从 **Demo** 到生产 系统

可靠性：让失败可控、可恢复

把 Agent 失败分层，设计超时、重试、检查点、补偿、降级和恢复；理解概率组件如何与确定性护栏组合，并能写出服务级目标与故障演练计划。

9.1 生产可靠性不是“多试几次”

Agent 的一次任务可能包含十几次模型与工具调用。即使每一步成功率是 98%，二十个相互依赖步骤全部成功的理想概率也只有约 67%。真实系统还会遇到网络、限流、数据变化、权限和并发问题。可靠性必须来自系统设计。

9.2 先建立故障分类

层级	例子	首选处理
模型	协议错误、选错工具、幻觉	校验、有限重试、换模型、拒答
工具	超时、限流、依赖不可用	退避、熔断、替代工具
状态	重复执行、版本冲突、丢检查点	幂等、事务、事件日志
上下文	约束丢失、证据过期	重新组装、来源时间校验
策略	越权、预算超限	权限层拒绝、停止、人工确认
业务	目标本身不可完成	部分结果、澄清、升级人工

错误分类应产生机器可读码。只有知道错误属于瞬时、永久、冲突还是需人工，恢复策略才不会盲目。

9.3 超时预算从外向内分配

如果用户请求最多等待 60 秒，内部步骤的超时总和不能无限扩张。为整体运行设置 **deadline**，工具每次调用从剩余时间获取子预算。达到 **deadline** 后取消未完成任务，返回已有结果与状态。

取消必须向下传播：模型流式请求、HTTP 调用、子 Agent 和后台任务都应响应取消。否则用户看见“已停止”，系统仍可能继续产生费用或副作用。

9.4 重试矩阵

- 网络断开、HTTP 429/503：有限次数指数退避，遵守 **Retry-After**。
- **schema** 不合法：把具体校验错误反馈给模型，通常重试 1–2 次。
- 参数业务非法：不要原样重试，需修正参数或重新规划。
- 权限拒绝：禁止重试绕过，向用户说明所需权限。
- 写操作结果未知：先用幂等键查询状态，不直接重复执行。

全局重试预算能防止嵌套组件各自重试三次，最终放大成几十次调用。每次重试都记录原因、等待时间和新参数。

9.5 检查点与恢复

长任务在关键步骤后保存检查点：计划版本、已完成步骤、**artifact** 句柄、工具调用状态、剩余预算和待确认动作。恢复时从最后一个**已提交且可验证**的检查点继续，而不是重新播放所有自然语言消息。

检查点需要版本 **schema**；代码升级后应能迁移旧状态，或明确拒绝并提供安全重启。包含凭证的状态不要明文持久化，只保存短期引用。

9.6 补偿事务

跨多个外部系统的流程通常无法使用数据库事务。可以采用 **Saga** 思路：每个正向动作对应补偿动作。例如创建日历事件后发送通知，通知失败时可以删除事件或标记为待处理。

补偿不等于完美撤销。邮件发出后无法收回，价格变化也可能使退款产生差额。设计时要标明“可逆、可补偿、不可逆”三种语义，并把不可逆步骤尽量放在最后和确认之后。

9.7 熔断、隔离与降级

依赖持续失败时，熔断器暂时停止调用，避免拖垮整个系统。不同租户、工具和任务类型应有独立并发池，防止一个大任务占满资源。降级路径可以是：换备用检索源、使用缓存、转为只读、生成草稿而不提交，或交给人工。

降级必须对用户可见。系统不应在没有实时数据时假装结果是最新的，应标注数据时间和缺失能力。

9.8 确定性外壳包住概率核心

模型擅长理解与候选生成；代码擅长约束与检查。以下部分优先使用确定性实现：权限、金额计算、schema、状态迁移、去重、预算、停止条件、引用存在性和最终提交。模型可以提出计划，但不能修改这些规则。

9.9 服务目标与错误预算

不要只监控 API 是否返回 200。Agent 的服务目标可以包括：任务成功率、危险动作误执行率、P95 完成时间、单任务成本、恢复成功率和人工接管率。对高风险动作，安全指标优先于平均完成率。

错误预算帮助团队决定是否继续加功能。当回归失败或越权事件超过预算时，应暂停扩张，先处理工具与评测缺口。

9.10 故障演练

定期注入：模型超时、工具返回畸形 JSON、检索源为空、网络断开、重复 webhook、状态库短暂不可用、批准后资源已变化、子 Agent 永不返回。验证系统是否停止在可理解状态，并能从检查点恢复。

为最小 Agent 加恢复

让每三次工具调用随机失败一次。加入错误分类、全局重试预算、幂等键、检查点和取消。运行 100 个任务，统计成功率、重复副作用次数、P95 步数和无法恢复的故障。

- □ 每种错误都有可恢复性分类，而非统一重试。
- □ 写操作能用幂等键确认是否已经完成。
- □ 长任务能从已验证检查点继续。
- □ 降级和数据过期会明确展示给用户。

评测与可观测性

从任务合同建立评测集，区分结果、过程与系统指标；掌握程序断言、模型评审和人工评审的组合；构造 `trace`，使线上失败能回流为离线回归样本。

10.1 没有评测，就没有可控迭代

换模型、改 `prompt`、加工具都可能同时改善一类任务并破坏另一类任务。只凭演示和主观聊天无法发现回归。评测的基本循环是：收集代表任务，冻结输入和标准，运行候选版本，比较指标，人工审查分歧，再决定是否发布。

10.2 评测单元是一份任务记录

每条样本建议包含：

- 输入目标与环境 `fixture`；
- 可用工具、权限和预算；
- 期望结果或允许结果集合；
- 必须满足和绝不能发生的条件；
- 评分 `rubric`、权重和证据；
- 难度、场景、风险和来源标签。

真实任务常不只有一个字符串答案。可以用状态断言，例如“创建了一份草稿但未发送”“最终报告包含五个来源且日期有效”。

层级	衡量内容	指标示例
结果	任务最后是否有用、正确、安全	完成率、事实正确率、违规率
过程	走法是否合理、可恢复	工具选择率、无效循环、重试次数
系统	成本与体验是否可接受	P50/P95 延迟、token、费用、接管率

10.3 三层指标

最终结果优先级最高。一个 Agent 即使计划文字漂亮，只要业务状态错误就应判失败。过程指标主要用于诊断和成本优化。

10.4 评分器的优先顺序

- 1. 确定性断言：schema、文件、数据库状态、测试、数值和引用 URL。
- 2. 领域规则：覆盖率、合规词、业务计算、权限策略。
- 3. 模型评审：语义正确性、完整性、表达质量等难以编码的维度。
- 4. 人工评审：校准主观维度，处理高风险和评分分歧。

能用程序判断的内容不要交给模型。使用 LLM-as-Judge 时，应提供清晰 rubric 与离散等级，要求引用被评答案中的证据，并用人工标注集测量一致性。

10.5 避免评测污染和过拟合

把样本分为开发集、回归集和保留测试集。开发人员可以看开发集；发布门槛使用稳定回归集；保留集不参与日常调 prompt。定期加入线上新失败，删除重复或不再代表业务的样本。

不要只测“正常问题”。至少覆盖：缺字段、矛盾输入、无答案、权限不足、工具超时、提示注入、重复请求、预算不足和用户中途取消。

10.6 成对比较与置信区间

开放式输出用绝对分数容易漂移。比较两个版本时，可以让评审对同一输入做成对选择，并随机左右顺序。报告胜、平、负以及分场景结果，而不是只报单一

均值。

小样本的 2 个百分点提升可能只是噪声。保留逐样本结果，使用 bootstrap 置信区间或至少报告样本数与变化样本。高风险发布还应逐条审查所有退化。

10.7 最小评测工具

examples/03_eval_harness.py 演示 JSON 样本、Agent 运行、确定性评分和聚合报告。一个可维护的评测命令应固定：代码版本、模型版本、prompt 版本、数据集版本、随机参数和环境 fixture。

```
python3 examples/03_eval_harness.py
# cases=5 passed=5 pass_rate=100.0%
```

真实模型存在波动，可对关键样本运行多次，报告 pass@1、最坏结果与方差。不要只挑一次最好结果展示。

10.8 Trace 是任务的可解释时间线

一个 trace 包含 run、step/span 与 event。每个 span 记录开始结束、父节点、组件、输入输出摘要、状态、错误、token、成本和 artifact。跨子 Agent 与工具调用传播 trace ID，才能还原端到端路径。

可观测性数据常包含 prompt、用户文档、工具参数和模型答案，是高敏感数据。默认脱敏、访问控制、加密与设置保留期；不要为了调试永久保存所有原文。

10.9 仪表盘与告警

仪表盘至少按版本、模型、任务类型、工具和租户切分。关注成功率、失败码、延迟分位数、步骤数、成本、缓存命中、重试和人工接管。告警应指向可行动问题，例如某工具的权限错误率突增，而不是笼统“Agent 质量下降”。

10.10 线上失败回流

建立闭环：线上 `trace` 被用户点踩或规则判失败；脱敏并最小化；工程师标注根因；生成可复现 `fixture`；加入回归集；修复后验证；发布并监控。没有这条链路，日志只是一座昂贵的数据仓库。

建立 50 条黄金集

从真实或模拟任务中选 50 条，按正常、边界、故障、安全分层。为每条至少写一个确定性断言。比较两个 `prompt` 或模型版本，输出总体和分层胜负，并逐条说明所有回归。

- 评测样本包含环境、权限、预算和禁止条件。
- 能确定性判断的维度没有交给 LLM 评分。
- 每次结果可追溯到代码、模型、`prompt` 和数据集版本。
- 线上失败可以脱敏后转成可复现回归样本。

安全、权限与人在回路

建立 Agent 威胁模型：控制提示注入、数据泄露、越权与供应链风险；按风险设计人工确认，并理解安全规则为何必须落在模型之外。

11.1 Agent 扩大了攻击面

普通聊天模型输出错误文字；Agent 可能读私有数据、调用 API、写文件、发消息或付款。输入来源也不再只有用户，还包括网页、邮件、文档、工具结果、记忆和第三方 Server。任何不可信内容都可能试图影响决策。

OWASP GenAI Security Project 持续整理 LLM 应用风险，是建立基线的重要入口 [7]。但威胁模型必须结合自己的资产、用户和工具权限。

11.2 画出信任边界

先列资产：用户数据、凭证、资金、生产环境、品牌发布权、内部知识。再列主体：用户、Host、模型提供商、MCP Server、工具后端、第三方内容和运维人员。最后画出数据跨越哪些边界，谁能发起什么动作。

每条边回答：是否认证、是否加密、是否最小权限、是否审计、是否能撤销、输入是否可信。安全评审的对象是完整数据流，不只是 system prompt。

11.3 提示注入是数据与指令混淆

直接注入来自用户；间接注入藏在网页、邮件或文档里。仅告诉模型“忽略恶意指令”不够，因为模型仍在同一上下文解释文字。

防御采用多层组合：

- 明确标记外部内容为不可信数据，并隔离其边界。
- 检索和工具按用户权限过滤，模型不能自行扩大范围。
- 敏感动作由策略引擎检查，与文本内容无关。
- 对外发送前展示目标、内容、附件与数据来源。
- 高风险场景在沙箱中解析文档，禁止任意网络和代码执行。

11.4 能力安全：最小权限与短期凭证

每个工具只获得完成动作所需的 `scope`。只读研究 `worker` 不应拥有发布权限；生成报告不需要读取用户全部邮箱。凭证尽量短期、按任务签发，并绑定用户、租户、工具和资源范围。

不要把密钥放进模型上下文。工具执行器在服务端注入凭证，模型只看到能力名称与必要结果。日志也应屏蔽令牌、Cookie、个人身份信息和敏感文档。

11.5 确认点按风险决定

人在回路不是每一步都弹窗。过多确认会让用户形成机械点击。确认应该出现在不可逆、外部可见、高价值、权限扩大或低置信度的关键边界。

风险	示例	交互
低	读公开资料、生成本地草稿	默认执行，提供活动记录
中	修改可恢复文件、创建草稿	批量预览或执行后可撤销
高	发邮件、发布内容、改共享数据	执行前逐项确认
极高	付款、删生产数据、法律承诺	强认证、双人复核或禁止自动化

确认令牌要绑定动作的规范化参数和版本。用户批准“发给 A 的草稿 v3”后，系统不能悄悄替换为“发给全部客户的 v4”。

11.6 数据最小化与生命周期

只收集任务所需数据；在进入模型前做字段裁剪或匿名化；区分开发日志和生产日志；为对话、`trace`、记忆、`artifact` 设置不同保留期。用户删除请求必须覆盖派生索引、缓存与备份策略。

多租户系统要在数据库查询、向量索引、缓存键、日志和 artifact 存储每一层隔离。只在 prompt 中写“不要访问其他客户”完全不构成隔离。

11.7 代码执行与浏览器控制

代码 Agent 应在临时、受限、可销毁环境中运行：非 root 用户、只挂载必要目录、网络域名白名单、CPU/内存/时间限制、禁止读取宿主密钥。提交修改前检查 diff 和测试；涉及 Git 推送、包发布或部署时独立确认。

浏览器 Agent 面对恶意页面、隐藏元素和会话 Cookie。使用独立浏览器资料、限制下载与域名、对付款或发送动作要求确认，并记录最终点击对象和页面状态。

11.8 供应链与生态资源

模型、Python 包、MCP Server、Skills、容器镜像和 Awesome 列表中的项目都属于供应链。安装前核验发布者、许可证、版本、依赖和最近维护；锁定版本，生成依赖清单，定期扫描漏洞。公开仓库的 Stars 不是安全证明。

11.9 红队测试

红队集应包含：要求泄露系统指令、网页内嵌注入、工具参数走私、跨租户查询、编码后的敏感内容、危险链接、重复批准、取消后仍执行、依赖返回恶意文本。每个样本必须检查最终业务状态，而非只看模型有没有说“拒绝”。

做一次权限演练

给研究 Agent 加一个发送邮件工具，但默认只有草稿权限。设计 20 个攻击样本，尝试利用网页内容或用户措辞让它直接发送。验证真正的发送端点始终要求绑定具体内容与接收者的批准令牌。

- □我画出了资产、主体、数据流和信任边界。
- □外部内容不能通过文字扩大工具权限。
- □密钥不进入模型上下文，凭证按任务最小化。
- □安全测试验证最终状态，而不只验证模型回答。

Agent 产品与交互设计

把 Agent 能力转成可理解、可控制的用户体验；设计委托、进度、确认、纠错和信任机制；用业务结果与人工成本衡量产品价值。

12.1 用户购买的是结果，不是自主性

“全自动 Agent”不是价值主张。用户关心的是能否更快、更准、更省心地完成任务，以及出错时能否发现和修正。产品定义应写成“为谁，在什么情境，把哪项指标从多少改善到多少”。

12.2 把任务边界展示清楚

好的委托界面让用户在开始前知道：目标、输入来源、输出、预计时间和费用、可访问范围、会产生的外部动作、需要确认的节点。开放聊天框适合探索，但高频业务应逐渐沉淀为表单、模板和可复用任务。

系统对含糊目标可以先生成“任务理解卡”：范围、假设、计划和完成条件。用户修改结构化字段比反复聊天纠正整段 prompt 更有效。

12.3 渐进式自主

同一产品可提供四档控制：

1. **建议**：只给方案，不执行。
2. **草稿**：执行可逆步骤，外部动作保留为草稿。
3. **确认后执行**：在关键边界请求批准。
4. **受限自动**：对已授权的低风险重复任务自动运行。

自主级别应按任务和工具决定，而不是一个全局开关。随着历史成功和用户授权可以提高，但始终提供暂停、撤销和查看活动的入口。

12.4 进度应该反映真实状态

不要展示虚假的“思考中”。用户需要看到可验证的阶段：正在核验 3/5 个来源、等待网站响应、已生成草稿、需要批准发送。长任务给预计范围、已消耗预算和下一检查点。

内部 chain-of-thought 不适合作为产品解释。更有用的是行动摘要：使用了哪些来源、调用了哪些工具、为什么需要确认、哪些信息仍不确定。

12.5 失败体验决定信任

失败界面回答四件事：发生了什么；哪些步骤已经完成；是否产生副作用；用户现在能做什么。提供从检查点继续、修改输入、换数据源、下载部分结果和转人工的操作。

“出错了，请重试”会抹掉 Agent 长任务的上下文价值。错误文案应关联任务和错误 ID，但不要泄露内部密钥、堆栈或其他租户信息。

12.6 确认与撤销的细节

确认框展示动作对象、差异、接收者、金额、可见范围和不可逆后果。批量操作提供筛选与逐项取消。确认后资源若变化，应使旧批准失效并重新展示 diff。

撤销应靠产品能力实现，而非承诺“AI 会处理”。对文件使用版本历史，对草稿支持删除，对业务记录使用补偿动作。不可撤销动作要更早预览、更晚提交。

12.7 信任来自证据和校准

展示来源、时间、测试结果和实际工具回执。系统应该在证据不足时降低确定性，而不是总用自信语气。置信度最好与可操作行为绑定：低置信度请求澄清或人工复核，高置信度仍受权限规则限制。

用户反馈不能只有点赞。提供“事实错误、漏项、未遵循要求、工具选错、

太慢、太贵、越权”等可诊断类别，并关联 trace。

12.8 产品指标树

层级	核心问题	指标示例
业务结果 任务质量	任务是否创造价值？ 结果是否可直接使用？	处理时长、转化、节省人时 完成率、一次通过率、修订率
控制与信任 效率	用户是否敢委托？ 系统代价是否合理？	批准率、撤销率、越权事件 延迟、成本、人工接管分钟数
留存	是否形成稳定 workflow？	周活任务、模板复用、留存

自动化率不能单独作为北极星。把需要人工修正的工作藏到流程末端，可能让自动化率上升、总耗时反而增加。

12.9 从辅助驾驶到自动化

新场景先运行 shadow mode：Agent 产生建议但不执行，与人工结果对比。达到质量门槛后开放草稿；再开放确认执行；只有低风险、高频、稳定任务进入受限自动化。每一级都需要退出和回滚条件。

画一个关键流程

为你的 Agent 画出从委托、运行、确认、完成到失败恢复的界面流程。为每个页面写出用户能看到的真实状态和可执行动作。找五位目标用户完成任务，记录他们在哪一步不敢继续。

- 产品价值用业务结果描述，而不是“更自主”。
- 用户能看到范围、权限、进度、证据和费用。
- 失败后能看到已完成部分、副作用与恢复选项。
- 自主级别按风险逐步开放，并有回滚门槛。

第 IV 部分

做出来：项目与长期成长

三个可交付的毕业项目

把前面章节组合成可展示的作品。三个项目分别覆盖知识工作、业务自动化和开发者工具；每个项目都有范围、里程碑、数据、评测、安全与演示要求。

13.1 作品集不是功能截图

一个有说服力的 Agent 项目需要回答：用户任务是什么；为什么需要 Agent；系统如何运行；失败如何处理；评测结果怎样；怎样复现。仓库至少包含 README、架构图、最小数据集、评测命令、样例 trace、安全说明和演示视频。

建议统一使用四周节奏：第一周建立任务合同和基线，第二周完成工具与主循环，第三周加入评测和可靠性，第四周进行用户测试与发布。先做到窄而完整，再增加范围。

13.2 项目 A：有证据的研究 Agent

13.2.1 任务定义

输入一个具体研究问题和允许来源，输出结构化报告、事实来源、冲突信息与未知项。适合市场研究、政策整理、技术选型或课程导航。

13.2.2 最小范围

- 搜索、打开网页、提取正文、保存证据四个只读工具。
- 编排器按子问题委托 3–5 个独立研究任务。
- 合并器去重并标记冲突，每个事实必须有 URL 和访问日期。

- 生成报告前运行覆盖度与引用支持检查。

13.2.3 评测集

准备 30 个问题：10 个单来源事实、10 个多来源比较、5 个没有公开答案、5 个来源相互冲突。指标包括证据召回率、事实正确率、引用精度、拒答质量、P95 时间和单报告成本。

13.2.4 安全边界

不登录私人账户，不下载来源不明的可执行文件，不把网页指令当作任务指令，不自动发布报告。保存最小网页片段并遵守站点访问规则与内容许可。

13.2.5 加分项

提供来源时间线、差异更新、断点恢复、搜索预算和“结论到证据”双向跳转。展示一个失败案例及修复前后的回归数据，比增加华丽 UI 更有价值。

13.3 项目 B：客服工单 Agent

13.3.1 任务定义

读取用户问题与账户的受限信息，检索知识库，生成回复草稿；在授权范围内执行退款申请或升级人工。重点是权限、业务规则与人在回路。

13.3.2 最小范围

- 路由：信息问答、账户问题、退款、无法识别。
- 工具：查订单、查政策、创建回复草稿、创建退款 proposal、转人工。
- 退款金额由代码计算，模型不能直接填写任意金额。
- 外发回复和退款提交都使用绑定参数的确认令牌。

13.3.3 评测集

从脱敏工单构造 100 条样本，覆盖多语言、情绪表达、缺失订单号、超期退款、重复请求、提示注入和跨账户查询。指标包括路由准确率、政策引用正确率、一次解决率、越权率和人工处理分钟数。

13.3.4 可靠性要求

所有写操作幂等；工具失败后保留草稿；状态变化写审计日志；依赖不可用时降级为人工队列；Agent 不能把“无法查询”编造成账户事实。

13.4 项目 C：代码维护 Agent

13.4.1 任务定义

在隔离工作区内读取仓库、定位问题、修改有限文件、运行测试、审查 diff，最终生成补丁和变更说明，不默认推送远端。

13.4.2 最小范围

- 工具：列文件、搜索、读文件、应用补丁、运行允许命令、查看 diff。
- 计划中标注将修改的模块和验收命令。
- shell 使用命令白名单、工作目录限制、资源与时间上限。
- 完成条件必须包含测试通过与 diff 自审。

13.4.3 评测集

在固定 commit 上准备 20–50 个真实小任务：修复单元测试、增加校验、更新文档和局部重构。用隐藏测试验证功能，另测改动范围、依赖变化、危险命令和运行成本。可参考 SWE-bench 的任务设计思想，但自己的项目应从小而可复现开始 [4]。

13.4.4 安全边界

默认无生产凭证和通用网络；不读取工作区外文件；不执行仓库内不可信脚本，除非允许列表明确授权；提交、推送、发布包和部署均需人工确认。

13.5 共同交付清单

1. 一条命令启动，一条命令跑评测。
2. 架构图标出模型、工具、状态、权限和数据边界。
3. 至少 30 条版本化评测样本和基线结果。

4. 三条完整 trace：成功、可恢复失败、安全拒绝。
5. 成本与延迟报告，注明模型和日期。
6. 威胁模型、已知限制、数据与许可证说明。
7. 3–5 分钟演示真实任务，不剪掉等待和失败恢复。

13.6 项目答辩的六个问题

1. 为什么不用确定性工作流或一次模型调用？
2. 最常见的三个失败是什么，如何发现？
3. 哪些动作模型永远无权直接执行？
4. 当前评测集遗漏了哪些真实分布？
5. 模型或框架替换后，哪些模块不需要改？
6. 再给两周，你会根据哪项数据决定下一步？

项目立项书

从三个项目中选一个，写一页立项书：目标用户、任务合同、非目标、架构、风险、四周里程碑、50 条评测样本如何获得、发布门槛。删掉所有无法在四周内验收的功能。

- ☐ 我的项目有真实任务、基线和可复现评测。
- ☐ Demo 同时展示成功、失败恢复和安全拒绝。
- ☐ 仓库公开说明数据来源、许可证和已知限制。
- ☐ 我能用指标而不是感觉解释架构选择。

30 天学习与长期维护路线

把全书转成每日可验收任务，建立“读原始资料、写最小实现、跑评测、复盘失败”的学习循环，并为长期跟踪高速变化的 Agent 生态建立维护机制。

14.1 每天必须留下一个产物

学习 Agent 最容易变成收藏链接。每天至少留下代码、测试、评测样本、架构图、trace、技术笔记或演示中的一种。输入资料的时间不应超过总学习时间的一半。

14.2 第 1 周：建立最小闭环

天	学习与实践	当日产物
1	区分调用、工作流与 Agent	一个场景的复杂度评分和任务合同
2	学习六层结构	Agent 数据流与三个故障归层
3	阅读有效 Agent 模式	同一任务的三种控制流草图
4	运行最小 Agent	可执行循环与结构化轨迹
5	接入一个真实模型	模型适配层和 10 条协议测试
6	加入停止与预算	五种停止原因及测试
7	周复盘	Demo、失败清单、下周基线

14.3 第 2 周：工具、上下文与知识

天	学习与实践	当日产物
8	写三个工具合同	schema、错误码、副作用分级
9	实现权限与 dry-run	proposal/commit 演示
10	实现幂等与重试	重复请求不会重复写入的测试
11	设计上下文预算	组装器与压缩策略
12	建立小型文档索引	20–50 篇文档及元数据
13	做检索与引用评测	30 题黄金集和 Recall@5
14	周复盘	比较三种检索方案并写结论

14.4 第 3 周：编排、评测与安全

天	学习与实践	当日产物
15	建立结构化计划	含依赖、预算和验收的计划
16	实现 worker 委托	委托合同与上下文裁剪
17	并行与合并	冲突识别和去重测试
18	建立 50 条评测集	分层标签和确定性断言
19	加 trace 与指标	成功和失败时间线
20	画威胁模型	资产、主体、边界和缓解措施
21	红队与复盘	20 条攻击样本及修复回归

14.5 第 4 周：做成可交付产品

天	学习与实践	当日产物
22	确定毕业项目范围	一页立项书与非目标
23	完成端到端 happy path	一条真实任务跑通
24	加检查点与恢复	故障注入演示
25	设计确认和失败界面	可点击原型或 CLI 交互
26	跑完整评测	基线报告和所有回归
27	用户测试	五位用户的观察与问题列表
28	性能和成本优化	前后对比表
29	整理开源仓库	README、许可证、安全说明

14.6 12 周进阶路线

完成 30 天后，不要立即追逐下一个框架。用三个月深化一个方向：

- 第 1–4 周：把毕业项目做到 100 条评测、可观测、可恢复。
- 第 5–8 周：选择一个框架重写关键控制流，比较抽象与性能。
- 第 9–10 周：阅读 5 篇核心论文，复现一个小实验。
- 第 11–12 周：贡献文档、测试或修复到一个上游项目，发布复盘。

14.7 如何读高速变化的资料

按四层获取信息：规范和论文用于理解机制；官方文档用于当前接口；成熟开源仓库用于工程模式；社区 Awesome 列表用于发现候选。新闻和短视频适合发现趋势，不适合成为实现依据。

每条资源记录：标题、类型、原始 URL、作者、访问日期、适用阶段、许可证、实践产物和最后核验。季度自动检查链接与仓库活跃度，但是否仍值得推荐需要人工判断。

14.8 框架学习策略

先用手写循环完成一个任务，再选择最匹配的框架。评价框架时看：状态是否显式、恢复是否原生、工具和模型是否可替换、trace 是否完整、部署和版本迁移成本如何。不要同时学五个框架的“Hello World”。

14.9 持续复盘模板

本周完成的真实任务：

本周新增的评测样本：

最常见失败及根因：

成功率 / P95 延迟 / 单任务成本：

删除了什么不必要复杂度：

下周只改善的一个指标：

启动第 1 天

现在就为一个真实场景完成复杂度评分和任务合同，把它提交到你的项目仓库。明天的任务不是继续收藏资料，而是画出六层数据流。

- □我能从零写出带校验、状态和终止的 Agent 循环。
- □我能设计可授权、可恢复、可审计的工具。
- □我有版本化评测集，能证明改动没有明显回归。
- □我完成了一个有 Demo、数据和安全说明的项目。

CHAPTER A

公开学习资源地图

本附录只收录公开课程、官方文档、论文和开源仓库入口。**公开可访问不等于可以复制再分发**：没有明确许可证的内容只分享原始链接；第三方仓库即使出现在Awesome 列表中，也必须单独核验当前许可证、维护状态与安全性。

A.1 第一梯队：从这里开始

资源	入口	最适合的学习产物
Anthropic: Building Effective Agents	https://www.anthropic.com/research/building-effective-agents	为一个任务选择最低复杂度模式
OpenAI: Practical Guide	https://openai.com/business/guides-and-resources/a-practical-guide-to-building-ai-agents/	Agent 设计与上线检查表
Microsoft AI Agents for Beginners	https://github.com/microsoft/ai-agents-for-beginners	按课程运行 Notebook 和一个项目
Hugging Face Agents Course	https://huggingface.co/learn/agents-course/	完成免费课程与结业任务
Google/Kaggle Agents Intensive	https://www.kaggle.com/learn-guide/5-day-agents	五天笔记、代码和实践作业
Datawhale Hello Agents	https://github.com/datawhalechina/hello-agents	中文系统学习与章节代码
MCP 官方文档	https://modelcontextprotocol.io/	实现最小 Client 与 Server

OWASP GenAI <https://genai.owasp.org/>
Security

为自己的 Agent 画威胁模型

A.2 基础、Prompt 与 Context

- **DeepLearning.AI 短课:** <https://www.deeplearning.ai/short-courses/>, 选择一门与当前项目直接相关的课程。
- **Prompt Engineering Guide:** <https://www.promptingguide.ai/>, 用于系统查阅方法与论文, 而非背模板。
- **OpenAI Cookbook:** <https://github.com/openai/openai-cookbook>, 结构化输出、工具、评测和应用示例。
- **Claude Cookbooks:** <https://github.com/anthropics/claude-cookbooks>, 工具、RAG 与多模态 recipes。
- **Gemini Cookbook:** <https://github.com/google-gemini/cookbook>, Gemini API 和长上下文示例。
- **Full Stack Deep Learning:** <https://fullstackdeeplearning.com/>, LLM 产品和生产系统课程。

A.3 框架与 SDK 选择表

项目	原始入口	先验证什么
LangGraph	https://github.com/langchain-ai/langgraph	状态图、持久化、恢复和人工检查点
OpenAI Agents SDK	https://github.com/openai/openai-agents-python	tools、handoff、guardrails、tracing
smolagents	https://github.com/huggingface/smolagents	教学友好度与 code agent 风险
AutoGen	https://github.com/microsoft/autogen	当前 API、事件驱动和多 Agent
CrewAI	https://github.com/crewAIInc/crewAI	角色/任务抽象是否真的降低复杂度
LlamaIndex	https://github.com/run-llama/llama_index	数据连接、检索和 agentic RAG

Semantic Kernel	https://github.com/microsoft/semantic-kernel	企业技术栈、插件和流程集成
Haystack	https://github.com/deepset-ai/haystack	显式 pipeline、RAG 与生产部署
AgentScope	https://github.com/openai/agentscope	多 Agent 控制、可观测与中文生态

框架 Star 数、许可与 API 会变化，本表不写静态排行榜。选型时在同一 20 条评测集上比较完成率、代码量、trace、恢复、延迟和迁移成本。

A.4 MCP、Skills 与工具生态

- MCP Python SDK: <https://github.com/modelcontextprotocol/python-sdk>
- MCP TypeScript SDK: <https://github.com/modelcontextprotocol/typescript-sdk>
- MCP Reference Servers: <https://github.com/modelcontextprotocol/servers>
- Awesome MCP Servers: <https://github.com/punkpeye/awesome-mcp-servers>
- Agent Skills Specification: <https://agentskills.io/>
- Anthropic Skills: <https://github.com/anthropics/skills>
- OpenAI Skills Catalog: <https://github.com/openai/skills>
- Vercel Skills CLI: <https://github.com/vercel-labs/skills>

安装前执行第八章的来源、权限、版本和沙箱检查。资源列表只负责发现，不负责背书。

A.5 可运行案例与产品

- Awesome LLM Apps: <https://github.com/Shubhamsaboo/awesome-llm-apps>
- GenAI Agents: https://github.com/NirDiamant/GenAI_Agents
- OpenHands: <https://github.com/OpenHands/OpenHands>
- browser-use: <https://github.com/browser-use/browser-use>
- Mem0: <https://github.com/mem0ai/mem0>
- Dify: <https://github.com/langgenius/dify>
- Langflow: <https://github.com/langflow-ai/langflow>
- Ollama: <https://github.com/ollama/ollama>

阅读案例时不要只运行 Demo。画出它的控制流、工具权限、状态存储、评测方法和失败恢复，再判断哪些设计能迁移到自己的任务。

A.6 评测、追踪与安全工具

- Promptfoo: <https://github.com/promptfoo/promptfoo>
- DeepEval: <https://github.com/confident-ai/deepeval>
- RAGAS: <https://github.com/explodinggradients/ragas>
- Phoenix: <https://github.com/Arize-ai/phoenix>
- Langfuse: <https://github.com/langfuse/langfuse>
- Opik: <https://github.com/comet-ml/opik>
- garak: <https://github.com/NVIDIA/garak>

工具无法替代评测设计。先定义任务、环境、断言与数据生命周期，再选择能实现它的产品。

A.7 公开视频入口

- Microsoft Developer Agents 课程: https://www.youtube.com/watch?v=OhI005_aJkA
- Full Stack Deep Learning: https://www.youtube.com/@The_Full_Stack
- DeepLearning.AI: <https://www.youtube.com/@Deeplearningai>
- Hugging Face: <https://www.youtube.com/@HuggingFace>
- LangChain: <https://www.youtube.com/@LangChain>
- Google for Developers: <https://www.youtube.com/@GoogleDevelopers>

视频只分享原始观看入口，不下载重传。看完一段内容，必须留下代码、评测、笔记或架构图之一。

A.8 持续更新的十个上游资源

本书维护过程中把下列 Awesome 仓库作为发现源。它们的内容不会自动复制进书稿；每个候选资源仍需回到原始页面核验。

上游	地址
Awesome LLM	https://github.com/Hannibal046/Awesome-LLM
Awesome LLMOps	https://github.com/tensorchord/Awesome-LLMOps

Awesome LLM Resources	https://github.com/WangRongsheng/awesome-LLM-resources
Agentic AI 中文导航	https://github.com/WenyuChiou/awesome-agentic-ai-zh
Agentic Patterns	https://github.com/nibzard/awesome-agentic-patterns
Awesome AI Agents	https://github.com/e2b-dev/awesome-ai-agents
Awesome Generative AI	https://github.com/steven2358/awesome-generative-ai
Generative AI Guide	https://github.com/aishwaryanr/awesome-generative-ai-guide
Awesome LLM Apps	https://github.com/Shubhamsaboo/awesome-llm-apps
Awesome MCP Servers	https://github.com/punkpeye/awesome-mcp-servers

A.9 季度维护协议

每季度执行：拉取上游更新；检查死链和重定向；核对官方入口、许可证与归档状态；记录重大 API 迁移；用新增资源解决具体学习缺口；更新访问日期和版本；在 changelog 说明新增、移除及原因。

本资料库不收录来源不明的网盘资源、盗版电子书、破解软件或被搬运的付费课程。所谓“全网资料包”最容易积累版权、恶意文件和过期资料风险；长期价值来自原创导读、核验和实践路径。

术语、模板与检查表

B.1 核心术语

Agent

模型在多步循环中观察环境、选择工具、更新状态并朝终止条件行动的系统。

Workflow

控制路径主要由代码预先定义的流程，局部节点可使用模型。

Tool

把模型提出的结构化意图转换为受控环境操作的接口。

State

系统跨步骤保存的结构化事实，包括任务、环境、预算与确认状态。

Context

某次模型调用实际可见的信息集合。

Memory

跨步骤或跨会话保存并可被选择性取回的信息。

RAG

先从外部知识检索证据，再让模型基于证据生成答案的系统模式。

Trace

一次任务从入口到模型、工具与子 Agent 的完整可观测时间线。

Guardrail

对输入、输出或动作进行检查和约束的机制；关键权限应由代码执行。

Idempotency

同一逻辑请求重复执行不会产生重复业务效果的性质。

Checkpoint

可恢复的已验证状态快照。

MCP

标准化 Agent 应用与外部能力/上下文连接方式的开放协议。

Skill

为一类任务打包的操作说明、脚本、参考资料和模板。

Handoff

把任务控制权和必要上下文交给另一个 Agent 或人工的过程。

LLM-as-Judge

使用模型按 rubric 评审输出的方法，需要人工校准与偏差控制。

B.2 任务合同模板

用户与场景：

目标：

输入与允许来源：

输出格式：

必须满足：

绝不能发生：

完成条件：

停止条件：

时间 / token / 费用预算：

需要人工确认的动作：

失败后的部分结果与恢复方式：

B.3 工具合同模板

名称 / 版本：

用途与不适用场景：

参数 schema：

返回 schema：

错误码与可重试性：

副作用等级：

幂等策略：

权限与确认：

超时 / 限流 / 成本：

审计字段：

撤销或补偿：

测试用例：

B.4 上线前检查表

B.4.1 任务与产品

- □ 用户、任务、输入、输出和完成条件已写清。
- □ 与普通代码、单次调用和固定工作流做过比较。
- □ 用户能看到 Agent 的范围、进度、证据和费用。
- □ 暂停、取消、修改、确认和失败恢复均可用。

B.4.2 工具与状态

- □ 工具 schema、错误码、副作用和权限有合同测试。
- □ 写操作有幂等键，高风险动作支持 dry-run。
- □ 状态结构化并带版本，长任务有检查点。
- □ 超时、重试、熔断、降级与取消经过演练。

B.4.3 数据与安全

- □ 已完成威胁模型、最小权限和租户隔离审查。
- □ 外部内容按不可信数据处理，不能改变权限。
- □ 凭证不进 prompt，日志经过脱敏并有保留期。
- □ 依赖、模型、MCP Server 和 Skills 已锁版本和核验来源。

B.4.4 评测与运维

- □ 代表性、边界、故障和安全样本均进入回归集。
- □ 关键业务状态用确定性断言验证。
- □ 版本、trace、成本、延迟和错误码均可观测。
- □ 有发布门槛、灰度、回滚和线上失败回流流程。

B.5 故障复盘模板

事件摘要与影响：
首次发生 / 发现 / 恢复时间：
用户可见症状：
实际业务状态与副作用：
根因层级（模型/工具/状态/上下文/策略/业务）：
为什么现有评测和监控没有提前发现：
临时缓解：
永久修复：
新增回归样本与负责人：
数据、权限或合规后续：

B.6 资源收录模板

资源名称：
原始 URL / 作者：
类型（规范/论文/课程/文档/仓库/视频）：
适合阶段与先修：
能产生的实践产物：
许可证 / 是否仅分享链接：
最后核验日期与版本：
维护状态和已知风险：
加入或移除理由：

参考文献

- [1] Agent Skills. Agent skills specification, 2026. URL <https://agentskills.io/>.
- [2] Anthropic. Building effective agents, 2024. URL <https://www.anthropic.com/research/building-effective-agents>.
- [3] Anthropic. Effective context engineering for ai agents, 2025. URL <https://www.anthropic.com/engineering/effective-context-engineering-for-ai-agents>.
- [4] Carlos E. Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. Swe-bench: Can language models resolve real-world github issues? In *International Conference on Learning Representations*, 2024. URL <https://www.swebench.com/>.
- [5] Model Context Protocol. MCP python sdk, 2026. URL <https://github.com/modelcontextprotocol/python-sdk>.
- [6] Model Context Protocol. Model context protocol documentation, 2026. URL <https://modelcontextprotocol.io/>.
- [7] OWASP Foundation. Owasp genai security project, 2026. URL <https://genai.owasp.org/>.

版本说明与致谢

你正在阅读《动手学 Agent》0.1.0-draft，生成日期为 2026-08-31。本版完成了从场景判断、最小循环到可靠性、安全、产品化与毕业项目的第一条完整学习路径。

本书不会以“收录最多链接”为目标。正文尽量保留跨模型、跨框架的稳定工程方法；附录链接到规范、官方课程、论文和原始仓库。若资源失效、许可变化或技术结论需要修正，请在 GitHub 仓库提交 Issue 或 Pull Request。

感谢所有公开课程、开源项目、标准与论文的作者。书中引用和链接不代表原作者为本书背书；第三方内容继续受各自许可证与使用条款约束。

下一迭代计划补充：真实模型适配示例、MCP Server 实战、RAG 小项目、更多评测 fixtures、三个毕业项目的参考实现，以及读者反馈中最常见的失败案例。

先做出一个，再让它可靠。

<https://github.com/DreamingRiverForUs/hands-on-agent>